

Windows Machine Hardening - Practical Implementation Guide

This document provides a structured and practical approach to hardening Windows machines by reducing the attack surface, enforcing secure configurations, and enabling monitoring controls across identity, network, operating system, and endpoint protection layers.

Phase 1 – Baseline Preparation

- 1 Install latest Windows updates.
- 2 Remove unused software and applications.
- 3 Use standard user accounts for daily work.

Phase 2 – Identity & Access Hardening

- 1 Configure strong password policy.
- 2 Set account lockout thresholds.
- 3 Disable or rename built-in Administrator.
- 4 Disable Guest account.
- 5 Remove unnecessary users from local Administrators group.

Phase 3 – OS & Kernel Security

- 1 Enable UAC (Always Notify).
- 2 Enable LSASS protection.
- 3 Enable Credential Guard.
- 4 Enable Secure Boot in BIOS/UEFI.

Phase 4 – Network Hardening

- 1 Enable Windows Firewall for all profiles.
- 2 Block inbound connections by default.
- 3 Disable SMBv1 protocol.
- 4 Enforce NTLMv2 authentication.
- 5 Secure RDP with NLA and restricted access.

Phase 5 – Service Surface Reduction

- 1 Disable Remote Registry.
- 2 Disable Xbox services.
- 3 Disable Bluetooth if not used.
- 4 Disable Fax and Print Spooler if not required.

Phase 6 – Endpoint Protection

- 1 Enable Microsoft Defender real-time protection.
- 2 Enable cloud protection and tamper protection.
- 3 Enable Attack Surface Reduction rules.
- 4 Enable Controlled Folder Access.

Phase 7 – Logging & Monitoring

- 1 Enable advanced audit policies.
- 2 Monitor security events (login, privilege use, policy changes, process tracking).
- 3 Integrate logs with SIEM where available.

Phase 8 – Data Protection

- 1 Enable BitLocker drive encryption.
- 2 Use TPM + PIN for OS drive.
- 3 Disable USB storage where required.

Phase 9 – Application Control

- 1 Disable Office macros by default.
- 2 Implement AppLocker or WDAC for application allowlisting.

Phase 10 – Browser Hardening

- 1 Enable SmartScreen.
- 2 Restrict extensions.
- 3 Disable password storage.
- 4 Enforce HTTPS.

Phase 11 – Patch & Vulnerability Management

- 1 Follow monthly patch cycles.
- 2 Use WSUS, SCCM, or Intune for patch deployment.
- 3 Perform vulnerability scans using enterprise tools.

Phase 12 – Compliance Alignment

- 1 Align hardening with CIS benchmarks.
- 2 Apply Microsoft Security Baselines.
- 3 Map controls to STIG and ISO 27001.

Critical Controls for Immediate Risk Reduction

- 1 Apply OS patches.
- 2 Remove unnecessary admin privileges.
- 3 Enable Defender and ASR rules.
- 4 Enforce firewall restrictions.
- 5 Disable SMBv1.
- 6 Enable audit logging.
- 7 Enable BitLocker.
- 8 Enable LSASS protection.